

Case study -

A sample checklist

Preparation

- Determine the exact location, sensitivity and relative value of all information in the organisation that needs to be protected.
- Make sure there are enough IT resources to respond to an attack or engage third-party support.
- Make sure the plan has full approval from the top of the organisation.
- Assign roles and responsibilities for all relevant stakeholders, including IT, human resources, internal communications, customer support, legal, public relations and advisors.
- Establish a chain of command that includes both IT and corporate leaders. Determine who will be incident commander, who will launch the incident response plan and who has the authority to stop work or shut down systems.
- Map the incident response workflow. Establish criteria for when human resources or the legal team will get involved, when the media will be alerted and when the regulators need to be contacted.
- Include contact information for all incident response team members, their backups, and managers.
- Identify cyber security regulatory requirements for the organisation and guidance on how to interact with law enforcement and other governmental authorities in the event of an incident.
- Develop and maintain a list of outside sources for forensics, hardware replacement, and related services that have approval to be used before, during or after an incident.
- Establish procedures for IT teams to receive alerts of all detected malware.
- Store privileged credentials, such as passwords, in a secure, centralised location such as a cloud-based vault.
- Automatically rotate privileged credentials, isolate privileged account sessions for temporary employees and regularly scan for orphan accounts of former employees that might still provide unauthorised access.
- Train all employees to report suspicious emails and activities that might compromise network security.
- Ensure that you have an up-to-date backup system ready.
- Establish a comprehensive communications plan to rapidly notify those inside and outside the organisation of any breach.

Continued..

Detection and analysis

- Have in place a detection strategy that automatically scans for any vulnerabilities and threats.
- Consider the use of tools such as endpoint detection and response platforms, anti-virus software, or user/entity behaviour analytics to detect malware.
- Keep up-to-date logs.
- Conduct testing to verify whether a network has been breached and to quickly identify the presence of any known or zero-day malware, as well as any persistent threats that may have evaded your existing cyber security defences.

Response

- Immediately contain any systems, networks, data stores and devices involved in the breach in order to isolate the incident and prevent it from causing widespread damage.
- Determine if any sensitive data has been stolen or corrupted and, if so, what the potential risk might be to your business.
- Eradicate infected files and, if necessary, replace hardware.
- Keep a comprehensive log of the incident and response, including the time, data, location and extent of damage from the attack. Include information such as: whether it was internal or external; how the incident was reported; when the security team got involved, etc.
- Preserve all the logs and details of the breach for further analysis.
- If necessary, prepare and release public statements about the nature of the breach, root causes, the extent of the attack, steps toward remediation, and an outline of future updates.
- Update any firewalls and network security to capture evidence that can be used for later analysis.
- If necessary, brief the legal team to see if the incident impacts any regulations.
- If necessary, contact law enforcement or regulatory authorities.

Recovery and follow-up

- Eliminate the security risk by applying patches, resetting passwords, etc., to make sure the attacker cannot regain access.
- Create a root cause identification to determine the attack path used so that security controls can be improved to prevent similar attacks in the future.
- Perform a vulnerability analysis to determine whether any other vulnerabilities may exist.
- Restore the systems to pre-incident state. Check for data loss and verify that system integrity, availability and confidentiality has been regained and that the organisation is back to normal operations.

Continued..

- Complete an incident response report and include all areas of the business that were affected by the incident.
- Determine whether management was satisfied with the response and whether additional training or technology is needed.
- Create a report to share any lessons that were learned.
- Review, test and update the cyber security incident response plan if necessary.
- Conduct testing or other security scans on a regular basis to ensure the health of systems, networks and devices.
- Conduct regular security training for all staff.